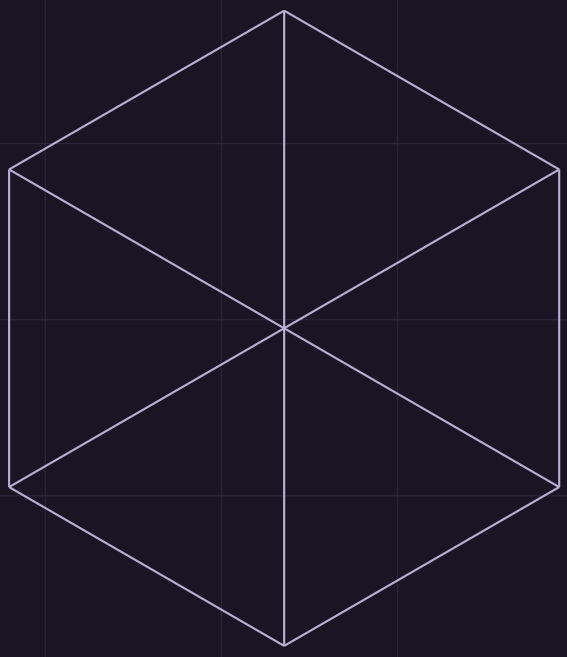
NEODA · WHITEPAPER TÉCNICO

Marco de Exposición Tecnológica 2027

Datos, IA y ciberriesgo: un modelo para cuantificar la exposición y priorizar inversiones ante NIS2, DORA y el Reglamento de IA.



Versión 1.0 · Noviembre 2026 · Documento de carácter informativo

Contenido

Índice

Capítulo	Título	Pág.
01	Resumen ejecutivo	3
02	El coste que no aparece en el cuadro de mando	4
03	Principios del marco	6
04	Definiciones y alcance	7
05	Modelo de exposición en euros	9
06	Dominio de datos	11
07	Dominio de inteligencia artificial	13
08	Dominio de ciberseguridad	15
09	Matriz de priorización	17
10	Gobierno, roles y decisiones	18
11	NIS2: gestión de riesgos e incidentes	19
12	DORA: resiliencia operativa digital	21
13	Reglamento de IA: riesgo y trazabilidad	22
14	Checklist de cumplimiento	23
15	Hoja de ruta de 90 días	24
16	Próximos pasos	25
A	Anexo A · Plantilla del registro de riesgos	26
B	Anexo B · Glosario	27
C	Anexo C · Preguntas frecuentes del comité	28

Una exposición que no se mide no se gestiona

Las organizaciones gastan cada año en datos, inteligencia artificial y ciberseguridad. Sin embargo, rara vez saben con precisión cuánto riesgo asumen, cuánto valor dejan sin capturar y qué inversiones reducen de verdad la exposición. El resultado es un presupuesto tecnológico que crece por inercia, decisiones tomadas con indicadores técnicos que el comité no entiende y, en el peor caso, un incidente o una sanción que nadie había puesto en la agenda.

Este documento propone un marco sencillo para resolver ese problema. Su objetivo es expresar la exposición tecnológica en términos financieros, de modo que el comité de dirección pueda compararla con cualquier otra decisión de negocio: un proyecto comercial, una inversión industrial o una contratación. El marco no pretende sustituir a los equipos técnicos ni a los responsables de cumplimiento; pretende darles un lenguaje común con la dirección.

El marco se compone de tres piezas:

- **Un modelo de exposición** que estima la pérdida anual esperada por dominio (datos, inteligencia artificial y ciberseguridad), a partir de probabilidades e impactos económicos.
- **Una matriz de priorización** que ordena las acciones según impacto económico y esfuerzo de ejecución, y propone qué hacer primero.
- **Un checklist de cumplimiento** alineado con la Directiva NIS2, el Reglamento DORA y el Reglamento Europeo de Inteligencia Artificial, con preguntas que el comité debería poder responder en cualquier momento.

Qué debería llevarse el comité

Tres ideas resumen el documento. La primera es que la exposición tiene un coste calculable, aunque la estimación sea imperfecta: una cifra con un margen de error razonable siempre es más útil que la ausencia de cifra. La segunda es que la inversión debe medirse por la reducción de exposición que produce, no por el volumen de actividad. La tercera es que el cumplimiento regulatorio no es una tarea separada del negocio, sino una condición para operar en determinados sectores y mercados.

Las cifras que aparecen como ejemplo a lo largo del documento son ilustrativas. No corresponden a ningún cliente ni a ningún sector en particular. Su función es mostrar cómo se aplica el método. Cada organización debe sustituirlas por sus propios datos antes de tomar decisiones.

A quién va dirigido

El documento está escrito para miembros de comités de dirección, directores financieros, responsables de tecnología, de seguridad de la información, de datos y de cumplimiento normativo. No requiere conocimientos técnicos avanzados. Los apartados 05 a 09 son los más útiles para el trabajo de análisis; los apartados 10 a 14 son útiles para la gobernanza y la preparación ante auditorías.

El coste que no aparece en el cuadro de mando

El cuadro de mando de la mayoría de organizaciones refleja bien lo que se gasta y peor lo que se arriesga. Se conocen los costes de licencias, de nube y de personal; se conocen, con más o menos detalle, los proyectos en curso y su avance. Lo que casi nunca aparece es la pérdida esperada: el valor que se perdería si un riesgo concreto se materializara, multiplicado por la probabilidad de que ocurra.

Esa ausencia tiene consecuencias. Una organización puede gastar mucho en seguridad y seguir expuesta a un riesgo grave que nadie ha cuantificado. Puede invertir en una plataforma de datos y no saber si esa inversión se traduce en decisiones mejores. Puede lanzar pilotos de inteligencia artificial sin un criterio claro para decidir cuáles escalar.

Tres patrones recurrentes

En el trabajo de diagnóstico se repiten tres patrones. Conviene reconocerlos porque cada uno tiene una señal de alerta distinta.

Patrón	Qué ocurre	Señal de alerta	Coste que no aparece
Exposición no medida	Accesos heredados, proveedores conectados a sistemas críticos y configuraciones cloud sin revisar.	Nadie puede responder cuántos accesos privilegiados existen ni quién los aprobó.	Pérdidas esperadas por incidentes, sanciones y paradas de servicio.
Datos sin uso	Información almacenada, duplicada y sin modelo de gobierno, que se paga cada mes sin alimentar decisiones.	Muchos informes distintos para la misma métrica y tiempos largos de respuesta.	Coste de plataforma y almacenamiento sin retorno medible.
IA sin perímetro	Pilotos aislados, herramientas no autorizadas y datos sensibles fuera de control.	Casos de uso que no pueden describirse con su propietario, sus datos y su impacto.	Riesgo regulatorio, fuga de información y retorno indefendible ante el comité.

Por qué ocurre

Las causas suelen ser organizativas más que técnicas. Los presupuestos de tecnología, seguridad y datos se gestionan en silos, con indicadores distintos y, a menudo, con responsables que no comparten objetivos. Cada área optimiza lo que puede medir: la seguridad mide alertas, los datos miden volumen y tecnología mide disponibilidad. Ninguna de esas métricas responde a la pregunta que importa al comité, que es cuánto valor se protege o se crea con cada euro.

A ello se suma la presión de los proveedores. Las ofertas comerciales se evalúan por funcionalidades y precio de licencia, pero rara vez por la reducción de exposición que aportan una vez desplegadas. Un proyecto puede cumplir su calendario y su presupuesto y aun así dejar la organización igual de expuesta que antes.

Qué cambia cuando se mide

Cuando la exposición se expresa en euros, la conversación cambia. Las áreas técnicas pasan a explicar riesgos en términos de impacto económico; la dirección puede comparar una inversión en seguridad con una inversión comercial; y los proyectos se priorizan por su contribución a la reducción del riesgo y al valor. El efecto más valioso no es la cifra en sí, sino la disciplina de preguntarse qué pasaría si el riesgo se materializara y cuánto nos costaría.

Cinco principios para medir sin engañarse

Antes de entrar en el modelo conviene fijar los principios que lo sostienen. Sirven como criterio cuando las cifras son incompletas, que será casi siempre.

1. Expresar en euros, aunque la cifra sea aproximada

Una estimación con un rango razonable es más útil que una descripción cualitativa del tipo «riesgo alto». El rango obliga a discutir supuestos, y la discusión de supuestos es donde se toman las buenas decisiones. Se recomienda trabajar con tres escenarios (conservador, central y severo) y mostrar siempre el rango, nunca solo una cifra.

2. Separar la exposición del gasto

Gastar más no equivale a estar menos expuesto. El marco exige que cada inversión declare qué riesgo reduce, en cuánto y con qué evidencia. Un gasto sin declaración de reducción de exposición se trata como gasto de operación, no como inversión de riesgo.

3. Tratar el cumplimiento como parte del negocio

Los requisitos de NIS2, DORA y del Reglamento de IA tienen coste de implantación, pero también evitan sanciones, facilitan la operación con clientes regulados y reducen el riesgo de interrupción. El marco los incorpora como riesgos con impacto económico, no como un anexo legal separado.

4. Asignar un propietario a cada riesgo

Un riesgo sin propietario no se gestiona. Cada elemento del modelo debe tener una persona responsable de su estimación, de las medidas de mitigación y de su revisión periódica. El propietario no tiene que ser técnico; debe ser alguien con capacidad de decisión sobre el proceso afectado.

5. Revisar con frecuencia y documentar las hipótesis

La exposición cambia cuando cambian los sistemas, los proveedores, las amenazas y la regulación. Se recomienda una revisión trimestral del modelo completo y una revisión inmediata después de cualquier incidente significativo. Todas las hipótesis deben quedar documentadas, de modo que puedan cuestionarse y corregirse sin repetir el análisis desde cero.

Los cinco principios no son reglas mecánicas. Son una forma de evitar los errores más frecuentes: tomar una cifra como verdad absoluta, confundir actividad con reducción de riesgo, tratar la regulación como un trámite y dejar riesgos sin responsable.

Términos que conviene fijar antes de empezar

El modelo utiliza un vocabulario reducido. Fijar las definiciones evita discusiones improductivas en el comité y permite comparar resultados entre áreas y periodos.

Término	Definición en este marco
Activo digital	Sistema, conjunto de datos, modelo de inteligencia artificial, servicio en la nube o dispositivo con valor para la organización.
Riesgo	Evento incierto que, si se produce, causa una pérdida económica o un incumplimiento. Se describe con una probabilidad anual y un impacto.
Probabilidad anual (P)	Frecuencia estimada con la que el riesgo se materializa en un año, expresada como porcentaje.
Impacto (I)	Pérdida económica total si el riesgo se materializa: coste directo, sanciones, paradas de servicio y efecto reputacional cuantificable.
Pérdida esperada	Producto de la probabilidad por el impacto. Es la cantidad que el modelo asigna a cada riesgo como coste anual esperado.
Exposición	Suma de las pérdidas esperadas de todos los riesgos de un dominio, más los costes de activos sin uso o sin retorno.
Mitigación	Medida que reduce la probabilidad o el impacto de un riesgo. Se mide por la reducción de pérdida esperada que produce.
Retorno	Beneficio medible de un activo o de una inversión, por ejemplo ahorro, ingreso adicional, tiempo recuperado o decisión mejorada.

Alcance del modelo

El modelo cubre tres dominios: datos, inteligencia artificial y ciberseguridad. Se excluyen de forma explícita otros riesgos tecnológicos, como la obsolescencia de hardware o los fallos de proveedores de telecomunicaciones, que pueden incorporarse si la organización lo considera necesario. La frontera del análisis debe quedar documentada al inicio, porque una exposición calculada sobre un alcance distinto no es comparable con otra.

Horizonte temporal

Las estimaciones se expresan como pérdida esperada anual. Para decisiones de inversión que duran varios años, se recomienda calcular también el valor acumulado a tres años, aplicando la misma probabilidad y el mismo impacto, y ajustando la reducción de exposición que aporte cada medida a lo largo del periodo.

Unidades y moneda

Todas las cifras se expresan en euros, sin impuestos, a precios constantes del año de análisis. Las organizaciones con operaciones en otras monedas deben convertir al tipo de cambio del

cierre del ejercicio y documentar el criterio. Los porcentajes de probabilidad se expresan siempre como frecuencia anual, nunca como probabilidad acumulada en un periodo distinto.

Cómo calcular la pérdida esperada anual

El núcleo del marco es una fórmula sencilla. Para cada riesgo identificado se estima su probabilidad anual y su impacto económico. La exposición de un dominio es la suma de sus pérdidas esperadas, a la que se añaden dos términos que recogen el coste de los activos que no producen retorno.

$$E_{dominio} = \Sigma\ (P_i \times I_i) + C_{sin\ uso} + C_{sin\ retorno}$$

donde P_i es la probabilidad anual del riesgo i, I_i su impacto en euros, $C_{sin\ uso}$ el coste anual de activos almacenados o contratados que no se utilizan en decisiones, y $C_{sin\ retorno}$ el coste anual de iniciativas que no tienen indicadores de retorno definidos.

Paso 1: inventario de riesgos

Se parte de un inventario de riesgos por dominio. El inventario debe ser concreto: «acceso privilegiado no revisado a la base de datos de facturación» es un riesgo útil; «riesgo de seguridad» no lo es. Cada riesgo se asocia a un activo digital y a un propietario. Un punto de partida práctico es revisar incidentes de los últimos tres años, auditorías internas, hallazgos de terceros y cambios recientes en sistemas.

Paso 2: estimación de la probabilidad

La probabilidad anual se estima a partir de la experiencia propia, de datos sectoriales y del juicio de los responsables técnicos. Se recomienda usar una escala de referencia común, para que todos los riesgos se valoren con el mismo criterio.

Nivel	Probabilidad anual	Interpretación
Muy baja	Menos del 1 %	Improbable en un año; se produce en el sector de forma excepcional.
Baja	Entre el 1 % y el 5 %	Se ha producido en el sector, pero no en la organización.
Media	Entre el 5 % y el 20 %	Se ha producido en la organización o en pares en los últimos años.
Alta	Más del 20 %	Se produce con regularidad o hay indicios activos de explotación.

Paso 3: estimación del impacto

El impacto incluye coste directo (recuperación, restitución de datos, horas de equipos), sanciones cuantificables, paradas de servicio y pérdida de ingresos durante la interrupción. El efecto reputacional se incluye solo cuando puede estimarse, por ejemplo mediante pérdida de clientes en un segmento concreto. Conviene calcular el impacto en tres escenarios, conservador, central y severo.

Paso 4: cálculo y comparación

Con probabilidad e impacto por riesgo, la pérdida esperada es el producto de ambos. Se suman los riesgos de cada dominio y se añaden los costes de activos sin uso o sin retorno. El resultado es la exposición anual del dominio, que se compara con el periodo anterior y con el presupuesto asignado.

Ejemplo ilustrativo

Supóngase un riesgo de acceso privilegiado no revisado a un sistema de facturación. Se estima una probabilidad anual del 4 % y un impacto central de 2,5 millones de euros, que incluye recuperación, sanciones y paradas. La pérdida esperada es de 100.000 € al año.

Una medida que consiste en revisar accesos cada trimestre y automatizar la retirada de permisos cuesta 30.000 € al año y reduce la probabilidad al 1 %. La nueva pérdida esperada es de 25.000 €. La reducción de exposición es de 75.000 € anuales, frente a un coste de 30.000 €. La medida se justifica por sí sola, sin necesidad de ningún otro argumento.

Estas cifras son hipotéticas. Su único objetivo es mostrar la lógica del cálculo.

Del almacenamiento a las decisiones

El dominio de datos es el que más inversión acumula en la mayoría de organizaciones y, paradójicamente, el que menos se evalúa. Las plataformas se contratan por capacidad, los proyectos se justifican por volumen de datos integrados y los indicadores de éxito suelen ser técnicos: número de fuentes conectadas, tiempo de carga, disponibilidad del entorno.

El marco propone medir el dominio por dos tipos de indicador: los de exposición, que describen qué podría costar, y los de retorno, que describen qué se obtiene.

Riesgos típicos del dominio

- **Activos sin propietario:** conjuntos de datos que nadie reclama y que se mantienen por inercia, con coste de almacenamiento y de copias de seguridad.
- **Clasificación incompleta:** datos personales o sensibles sin etiquetar, lo que dificulta cumplir el RGPD y limitar accesos.
- **Linaje incompleto:** imposibilidad de explicar de dónde procede una cifra del cuadro de mando, lo que erosiona la confianza en los datos.
- **Duplicidad:** la misma información en varios sistemas, con versiones distintas y procesos de sincronización frágiles.
- **Dependencia de proveedor:** formatos o servicios que impiden migrar sin coste elevado.

Indicadores de exposición

Indicador	Cómo se calcula	Umbral orientativo
Activos sin propietario	Porcentaje de conjuntos de datos sin responsable asignado.	Menos del 5 % del inventario.
Datos sensibles sin clasificar	Porcentaje de activos con datos personales sin etiqueta de sensibilidad.	Cero en sistemas críticos.
Coste de datos sin uso	Coste anual de almacenamiento y procesos de activos sin consultas en los últimos 12 meses.	Revisión anual de cada activo.

Indicadores de retorno

Indicador	Cómo se calcula	Lectura para el comité
Tiempo hasta la respuesta fiable	Días desde que se formula una pregunta de negocio hasta que se responde con datos validados.	Mide la agilidad de la decisión.
Informes con fuente única	Porcentaje de métricas del cuadro de mando con una sola fuente validada.	Mide la confianza en las cifras.
Decisiones apoyadas en datos	Número de decisiones de comité documentadas con un indicador del modelo de datos.	Mide el uso real de la plataforma.

Un ejemplo práctico: una organización con cuatro entornos de datos paralelos, cada uno con su propio coste, puede consolidarlos en uno solo con un modelo de gobierno único. El ahorro de plataforma es el indicador más visible, pero el valor principal suele estar en que el informe comercial pasa de ser semanal a diario, porque la fuente deja de cambiar según quién lo prepara.

Los proyectos de datos deben cerrarse con un criterio explícito: qué decisión mejora, qué indicador lo demuestra y quién es responsable de mantenerlo. Un proyecto que solo entrega infraestructura no se considera completado en el marco.

Pilotos, casos de uso y control

La inteligencia artificial concentra hoy la mayor parte de la presión inversora y, al mismo tiempo, la mayor incertidumbre. Muchas organizaciones tienen decenas de pilotos abiertos, herramientas adoptadas por equipos individuales y datos que salen del perímetro sin control. Sin un inventario y sin criterios de escalado, es difícil saber qué funciona, qué riesgo asume la organización y qué cumple la normativa.

Inventario de casos de uso

El primer paso es un inventario que incluya todos los casos de uso, aunque sean experimentales. Para cada uno debe constar el propietario, el proceso de negocio afectado, los datos que utiliza, el modelo o herramienta empleada, si hay supervisión humana y cuál es el impacto esperado. Un caso que no puede describirse con estos elementos no debe escalarse a producción.

Riesgos típicos del dominio

- **Fuga de información:** datos confidenciales introducidos en herramientas externas sin acuerdo de tratamiento ni controles.
- **Decisiones sin trazabilidad:** salidas de modelos que influyen en decisiones de negocio sin registro de su origen ni de quién las aprobó.
- **Sesgos y errores no detectados:** resultados incorrectos o discriminatorios que se propagan porque nadie revisa muestras periódicamente.
- **Dependencia de un proveedor de modelos:** cambios de precio, de condiciones o de comportamiento que afectan a procesos críticos.
- **Incumplimiento normativo:** sistemas de alto riesgo desplegados sin evaluación, documentación ni supervisión humana.

Cómo valorar un caso de uso

Cada caso de uso se evalúa con dos preguntas. La primera es cuánto valor genera, medido en margen, coste evitado o tiempo recuperado, y con qué evidencia. La segunda es cuánta exposición introduce, medida como pérdida esperada por fuga de datos, error de decisión o incumplimiento. Un caso con alto valor y baja exposición se escala; uno con bajo valor y alta exposición se detiene; los intermedios se rediseñan antes de decidir.

Caso de uso	Valor anual estimado	Exposición anual estimada	Decisión
Asistente interno con datos propios y registro de consultas	Alto (ahorro de horas)	Baja (datos no salen del perímetro)	Escalar con revisión trimestral.
Herramienta externa de redacción sin contrato de tratamiento	Bajo	Alta (fuga de información)	Detener y sustituir por opción autorizada.
Modelo de precios con validación humana	Alto (margen)	Media (error de decisión)	Escalar con control de muestras.

Los valores de la tabla son ejemplos de clasificación, no mediciones. Muestran cómo se aplican los criterios de decisión.

Supervisión humana

El marco exige que todo caso de uso que influya en decisiones relevantes tenga un punto de supervisión humana definido: quién revisa, con qué frecuencia, con qué criterios y qué ocurre cuando la revisión detecta un error. La supervisión no es una formalidad; es el control que permite demostrar que la organización gobierna sus sistemas.

Exposición conocida, medida y bajo control

La ciberseguridad es el dominio donde el modelo de pérdida esperada tiene una aplicación más directa, porque existen datos sobre incidentes, costes de recuperación y sanciones. Aun así, muchas organizaciones siguen midiendo la seguridad por número de alertas, de parches aplicados o de herramientas desplegadas, que no dicen nada sobre la exposición real.

Superficie de ataque y cadena de suministro

La superficie de ataque incluye los accesos expuestos a internet, las identidades privilegiadas, los servicios en la nube, los dispositivos y los sistemas de terceros conectados a la red. La cadena de suministro añade proveedores con acceso a sistemas críticos, software de terceros y servicios gestionados. Un inventario completo de estos elementos, con su propietario y su nivel de criticidad, es la base de cualquier estimación de riesgo.

Indicador de exposición	Qué mide	Frecuencia de revisión
Identidades privilegiadas sin revisión	Cuentas con permisos elevados que no se han revisado en los últimos 90 días.	Trimestral
Proveedores con acceso a sistemas críticos	Terceros con conexión a sistemas de negocio críticos, sin evaluación de seguridad vigente.	Semestral
Configuraciones cloud desviadas	Recursos en la nube que incumplen la línea base de configuración.	Continua o semanal
Vulnerabilidades críticas abiertas	Vulnerabilidades de criticidad alta en activos expuestos, con su antigüedad.	Semanal

Detección y respuesta

La detección y la respuesta determinan cuánto dura un incidente y cuánto cuesta. El indicador principal es el tiempo medio de detección y el tiempo medio de contención. Una organización que reduce a la mitad el tiempo de contención reduce, en la práctica, el impacto económico de los incidentes que se producen, aunque su probabilidad no cambie.

En el ejemplo de referencia de este documento, una entidad financiera ilustrativa centraliza la detección, automatiza playbooks de respuesta para los incidentes más frecuentes y realiza simulacros trimestrales con el comité de riesgos. El resultado modelado es una reducción del tiempo medio de contención de más del 70 %. La cifra es ilustrativa, pero el mecanismo es el habitual: menos tiempo de exposición activa, menor coste de recuperación.

Preparación para la auditoría y el regulador

La ciberseguridad moderna no se evalúa solo por su eficacia técnica, sino por su capacidad de demostrar control. Eso implica políticas documentadas, evidencias de ejecución, registros de incidentes y planes de respuesta probados. El marco incluye estas evidencias en el checklist del

capítulo 14, porque son las que se solicitan en una inspección.

Un error habitual es preparar la documentación justo antes de una auditoría. Las evidencias deben generarse de forma continua en el funcionamiento ordinario, para que el cumplimiento sea un subproducto de la operación y no un proyecto aparte.

Impacto frente a esfuerzo

Una vez calculada la exposición, el comité necesita decidir qué hacer primero. La matriz de priorización cruza dos variables: el impacto económico esperado de cada acción, medido como reducción de pérdida esperada o como retorno, y el esfuerzo de ejecución, medido en coste, tiempo y dependencias.

Construcción de la matriz

El impacto se estima como la reducción anual de pérdida esperada que produce la acción, más su retorno directo si lo tiene. El esfuerzo se estima en una escala de tres niveles: bajo (menos de tres meses y sin nuevas contrataciones), medio (entre tres y seis meses, o con un proveedor adicional) y alto (más de seis meses, o con cambios de arquitectura).

Zona	Criterio	Decisión
Hacer ya	Impacto alto y esfuerzo bajo o medio.	Asignar propietario y plazo en el siguiente ciclo de comité.
Planificar	Impacto alto y esfuerzo alto.	Hoja de ruta por fases, con coste, retorno y criterio de éxito por iniciativa.
Automatizar	Impacto medio y esfuerzo bajo.	Delegar en el equipo operativo, con métricas mensuales.
Revisar	Impacto bajo, cualquier esfuerzo.	Mantener en observación y reevaluar en la siguiente auditoría.

Cómo usar la matriz en el comité

La matriz no sustituye el juicio de la dirección, pero le da un punto de partida ordenado. Se recomienda presentarla con tres o cuatro acciones por zona como máximo, para que la discusión se centre en las decisiones que importan. Cada acción debe llegar con su hipótesis de impacto, su rango de estimación y su propietario.

Errores frecuentes al priorizar

- **Priorizar por facilidad:** se hacen primero las acciones fáciles aunque tengan poco impacto, y las de impacto alto se posponen indefinidamente.
- **Priorizar por novedad:** las iniciativas más visibles o más de moda desplazan a medidas básicas de control.
- **Ignorar dependencias:** una acción de alto impacto puede depender de otra de bajo impacto que no se ha hecho.
- **Medir actividad, no reducción:** se cuentan proyectos terminados en lugar de exposición eliminada.

Para evitar estos errores, conviene revisar la matriz al cierre de cada trimestre y comparar las acciones previstas con las que realmente redujeron exposición. La diferencia entre ambas es la información más valiosa para ajustar la siguiente planificación.

Quién hace qué en el modelo

Un modelo de exposición solo funciona si tiene propietarios claros y un calendario de decisiones. Este capítulo propone una distribución de roles que puede adaptarse al tamaño y al sector de la organización.

Rol	Responsabilidad principal	Frecuencia
Comité de dirección	Aprueba el apetito de riesgo, el presupuesto y las prioridades de la matriz.	Trimestral
Responsable de riesgos	Mantiene el modelo, coordina las estimaciones y prepara los informes.	Mensual
Propietarios de activo	Estiman probabilidad e impacto de sus riesgos y ejecutan las medidas.	Mensual
Responsable de cumplimiento	Verifica la trazabilidad frente a NIS2, DORA y el Reglamento de IA.	Trimestral
Equipos técnicos	Aportan evidencias, métricas y el estado de las medidas.	Continua

Calendario de decisiones

Se recomienda un calendario anual con tres tipos de reunión. Una revisión trimestral del modelo completo, con presentación de la exposición del periodo y de la matriz actualizada. Una revisión mensual operativa con los propietarios de activo, centrada en medidas en curso y riesgos que cambian. Y una revisión extraordinaria tras cualquier incidente significativo, con análisis de causa y actualización de estimaciones.

Documentación mínima

El modelo debe conservar cuatro documentos: el inventario de riesgos con sus propietarios, el registro de hipótesis con su fecha y su autor, el registro de decisiones del comité y el informe trimestral de exposición. Con esos cuatro documentos, cualquier auditor o miembro nuevo del comité puede reconstruir cómo se llegó a cada decisión.

Comunicación con el comité

El informe trimestral debe caber en pocas páginas. Una estructura útil consiste en la exposición total del periodo y su variación, los tres riesgos que más contribuyen, el estado de las medidas prioritarias, las decisiones pendientes y las hipótesis que han cambiado. Los detalles técnicos se dejan en anexo, disponibles para quien los necesite.

Gestión de riesgos e incidentes

La Directiva (UE) 2022/2555, conocida como NIS2, establece un marco común de ciberseguridad para sectores considerados esenciales e importantes en la Unión Europea. Su aplicación concreta depende de la transposición de cada Estado miembro, por lo que las obligaciones deben verificarse con el texto nacional vigente y con el asesoramiento legal de la organización.

Desde el punto de vista de este marco, NIS2 aporta dos bloques de exigencias que encajan directamente con el modelo de exposición: la gestión de riesgos de ciberseguridad y la notificación de incidentes.

Gestión de riesgos

La directiva exige medidas proporcionadas al riesgo, que cubran al menos políticas de análisis de riesgos y de seguridad de sistemas, gestión de incidentes, continuidad de negocio y gestión de crisis, seguridad de la cadena de suministro, seguridad en la adquisición y el desarrollo de sistemas, y formación. El modelo de exposición proporciona la base cuantitativa para justificar y priorizar estas medidas.

Notificación de incidentes

NIS2 establece plazos de notificación escalonados a la autoridad competente. Según el texto de la directiva, debe enviarse un aviso temprano en un plazo de 24 horas desde que se tiene conocimiento del incidente significativo, una notificación de incidente en 72 horas y un informe final en un plazo de un mes. Estos plazos deben incorporarse al plan de respuesta, con responsables identificados y plantillas preparadas de antemano.

Responsabilidad de los órganos de dirección

Uno de los cambios más relevantes de NIS2 es que la responsabilidad de aprobar y supervisar las medidas de ciberseguridad recae en los órganos de dirección. Los directivos deben recibir formación suficiente para entender los riesgos. El modelo de este documento está pensado precisamente para facilitarla: convierte riesgos técnicos en magnitudes que la dirección puede evaluar y aprobar.

Aplicación práctica

Exigencia	Evidencia que se debe poder mostrar	Cómo lo cubre el modelo
Análisis de riesgos	Inventario de riesgos, hipótesis y resultados.	Pérdida esperada por riesgo y dominio.
Gestión de incidentes	Procedimiento, registros y simulacros.	Tiempo de contención como indicador.
Cadena de suministro	Evaluación de proveedores y cláusulas contractuales.	Proveedores con acceso crítico como indicador.
Formación de la dirección	Registro de sesiones y decisiones.	Informe trimestral y registro de decisiones.

Esta tabla es orientativa y no sustituye el análisis jurídico de cada organización.

Resiliencia operativa digital

El Reglamento (UE) 2022/2554, conocido como DORA, establece requisitos uniformes de resiliencia operativa digital para entidades financieras y para los proveedores de servicios de tecnología de la información y la comunicación que les prestan servicios. Es aplicable desde el 17 de enero de 2025.

DORA se organiza en cinco pilares: gestión del riesgo TIC, gestión y notificación de incidentes, pruebas de resiliencia operativa, gestión del riesgo de terceros proveedores TIC y compartición de información sobre amenazas.

Relevancia para organizaciones no financieras

Aunque DORA se dirige a entidades financieras, su influencia se extiende a las empresas que les prestan servicios tecnológicos. Un proveedor de nube, de datos o de software que atiende a una entidad regulada puede recibir exigencias contractuales y de evidencias derivadas de DORA. Las organizaciones de otros sectores deben conocer esas exigencias si son proveedores de entidades financieras.

Gestión del riesgo de terceros

El reglamento exige un registro de información sobre los acuerdos con proveedores TIC, una evaluación previa del riesgo antes de contratar, cláusulas contractuales mínimas y una estrategia de salida para los servicios críticos. En el modelo de exposición, este bloque corresponde a los proveedores con acceso a sistemas críticos y a la dependencia de un proveedor concreto como riesgo específico.

Pruebas y continuidad

DORA exige pruebas periódicas de resiliencia, incluidas pruebas de penetración basadas en amenazas para las entidades que el reglamento determine. Los planes de continuidad deben probarse y actualizarse. El modelo recoge estas pruebas como medidas de reducción de impacto, con su coste y su efecto medible sobre el tiempo de recuperación.

Pilar DORA	Qué se debe demostrar	Indicador en el modelo
Gestión del riesgo TIC	Marco de gestión documentado y revisado.	Riesgos con propietario y revisión periódica.
Incidentes	Clasificación, notificación y análisis de causa.	Tiempo de contención y de notificación.
Pruebas	Programa de pruebas con resultados y medidas.	Medidas derivadas de pruebas con reducción de exposición.
Terceros	Registro, evaluación y estrategia de salida.	Proveedores críticos y dependencia.

Riesgo, trazabilidad y supervisión

El Reglamento (UE) 2024/1689, o Reglamento Europeo de Inteligencia Artificial, establece un marco basado en el nivel de riesgo de cada sistema. Algunas prácticas están prohibidas; los sistemas de alto riesgo tienen requisitos específicos de gestión de riesgos, calidad de datos, documentación, registro, transparencia, supervisión humana y robustez; y para el resto existen obligaciones de transparencia en determinados casos.

El reglamento entró en vigor en agosto de 2024 y se aplica de forma escalonada. Las fechas que afectan a cada tipo de sistema han sido objeto de debate y pueden variar, por lo que deben verificarse en el texto oficial y con el asesoramiento legal correspondiente antes de planificar cualquier despliegue.

Clasificación de los sistemas

El primer paso es clasificar cada sistema de IA de la organización según el reglamento. Esa clasificación determina las obligaciones aplicables y, por tanto, el coste de cumplimiento y la exposición asociada. Un sistema que decide sobre el acceso a servicios esenciales o sobre el empleo puede estar en la categoría de alto riesgo; un asistente interno de redacción normalmente no lo estará, aunque sí puede tener obligaciones de transparencia.

Trazabilidad y supervisión

Para los sistemas de alto riesgo, el reglamento exige registros que permitan rastrear su funcionamiento, documentación técnica suficiente, medidas de supervisión humana y gestión de riesgos durante todo el ciclo de vida. Estas exigencias se traducen en procesos concretos: versionado de modelos, registro de entradas y salidas relevantes, revisión periódica de muestras y procedimientos para detener o corregir un sistema.

Requisito	Evidencia habitual	Coste de exposición si falta
Inventario de sistemas	Registro con propietario, datos y clasificación.	Incumplimiento y decisiones no auditables.
Gestión de riesgos	Evaluación documentada y medidas de mitigación.	Daño a personas o a la organización no previsto.
Calidad de datos	Descripción de fuentes, sesgos y pruebas de calidad.	Errores sistemáticos en decisiones.
Supervisión humana	Procedimiento y registro de revisiones.	Decisiones automáticas sin control.
Transparencia	Información a usuarios cuando corresponda.	Sanciones y pérdida de confianza.

Como en los capítulos anteriores, la tabla es orientativa. La clasificación final de cada sistema requiere análisis jurídico y técnico caso por caso.

Preguntas que el comité debería poder responder

El checklist reúne las preguntas que un comité debería poder contestar con evidencias en cualquier momento. No es un test de aprobado o suspenso; es una herramienta para identificar huecos y priorizar su cierre.

	Pregunta	Marco de referencia
☐	¿Existe un inventario actualizado de activos digitales, con propietario y criticidad?	NIS2 · DORA
☐	¿Se han identificado y evaluado los riesgos por dominio, con probabilidad e impacto?	NIS2 · Modelo
☐	¿Están documentados los proveedores TIC y sus accesos a sistemas críticos?	DORA · NIS2
☐	¿Existe una estrategia de salida para los servicios críticos de terceros?	DORA
☐	¿Se notifican los incidentes significativos dentro de los plazos legales?	NIS2 · DORA
☐	¿Los planes de continuidad y de respuesta se prueban al menos una vez al año?	DORA · NIS2
☐	¿Se revisan periódicamente los accesos privilegiados?	NIS2 · Buenas prácticas
☐	¿Hay un registro de los sistemas de IA en uso y de su nivel de riesgo?	Reglamento IA
☐	¿Existe supervisión humana definida para los casos de uso que influyen en decisiones?	Reglamento IA
☐	¿Los sistemas de IA de alto riesgo cuentan con documentación técnica y registros?	Reglamento IA
☐	¿Está clasificado el dato por sensibilidad, con linaje auditable?	RGPD · Buenas prácticas
☐	¿Se calcula la exposición anual en euros y se revisa cada trimestre?	Este marco
☐	¿Las decisiones del comité quedan registradas con su hipótesis y su responsable?	Gobierno · Este marco

Un resultado de «no» en cualquiera de las preguntas no implica incumplimiento automático. Indica que la organización no puede demostrarlo hoy, y que debe decidir si lo corrige, lo acepta o lo documenta como riesgo residual.

Cómo usar el checklist

Se recomienda responder el checklist una vez al año como ejercicio completo y cada trimestre en sus preguntas críticas. Cada respuesta afirmativa debe apoyarse en una evidencia concreta, con fecha y responsable. Las respuestas negativas se convierten en entradas de la matriz de priorización.

Cómo empezar sin paralizar la operación

Implantar el marco de una vez no es realista. Una hoja de ruta de 90 días permite obtener resultados visibles y establecer la disciplina de medición sin interrumpir la operación.

Semanas	Actividad	Entregable
1 a 2	Alcance, propietarios y calendario de comité.	Documento de alcance firmado por la dirección.
3 a 5	Inventario de activos y riesgos por dominio.	Inventario inicial con propietarios.
6 a 8	Estimación de probabilidad e impacto en tres escenarios.	Exposición inicial por dominio con rango.
9 a 10	Matriz de priorización y selección de acciones.	Cuatro a seis acciones con propietario y plazo.
11 a 12	Primer informe al comité y registro de decisiones.	Informe trimestral versión 1.0.

Criterios de éxito a los 90 días

- Todos los dominios tienen inventario, propietarios y exposición estimada.
- El comité ha tomado al menos tres decisiones basadas en el modelo.
- Existe un calendario de revisión y un responsable de mantenerlo.
- Las hipótesis principales están documentadas y se pueden revisar.

Lo que no conviene hacer

No conviene intentar cuantificar todos los riesgos desde el primer día. Es preferible empezar por los diez de mayor impacto y ampliar el inventario en los ciclos siguientes. Tampoco conviene esperar a tener datos perfectos: las primeras estimaciones serán imprecisas y eso es normal. Lo importante es que el proceso de estimación exista y se repita.

Errores frecuentes y primer paso

Errores frecuentes

- **Confundir precisión con utilidad:** una cifra con decimales no es más correcta si los supuestos son débiles.
- **Medir lo fácil:** se miden alertas o licencias porque son sencillas de contar, no porque reflejen la exposición.
- **Tratar el cumplimiento como proyecto:** las evidencias se preparan antes de cada auditoría y se abandonan después.
- **No asignar propietarios:** el modelo se convierte en un documento que nadie actualiza.
- **No cerrar el ciclo:** se presentan estimaciones pero no se comparan con los resultados reales.

Primer paso recomendado

La forma más útil de empezar es una primera conversación de 45 minutos con el comité o con su responsable de tecnología. En esa sesión se pueden identificar los tres riesgos prioritarios, el retorno potencial de la información disponible y el alcance razonable de un primer ciclo de trabajo.

Un primer ciclo completo suele durar entre dos y tres semanas. Incluye inventario de activos y riesgos, cálculo de la exposición inicial, matriz de priorización y una hoja de ruta con coste y plazo por iniciativa. El resultado es un documento que el comité puede aprobar y un conjunto de indicadores que se revisan cada trimestre.

Contacto

Para solicitar una conversación inicial o más información sobre el marco, escriba a **contacto@neoda.com**. Se firma un acuerdo de confidencialidad (NDA) desde la primera reunión, y las respuestas llegan en un plazo máximo de 24 horas laborables.

Este documento tiene carácter informativo y no constituye asesoramiento jurídico, financiero ni de inversión. Las cifras son ilustrativas. Las referencias normativas deben contrastarse con el texto oficial vigente y con el asesoramiento profesional correspondiente.

Plantilla del registro de riesgos

Esta plantilla recoge los campos mínimos de cada riesgo del modelo. Puede copiarse a una hoja de cálculo o a cualquier herramienta de gestión. Los valores de ejemplo son hipotéticos.

Campo	Descripción	Ejemplo (hipotético)
ID	Identificador único del riesgo.	DAT-007
Dominio	Datos, IA o ciberseguridad.	Ciberseguridad
Activo asociado	Sistema, conjunto de datos o caso de uso afectado.	Sistema de facturación
Descripción	Evento concreto que causaría la pérdida.	Acceso privilegiado no revisado
Propietario	Responsable de estimar y mitigar el riesgo.	Director de sistemas
Probabilidad anual (P)	Porcentaje estimado, con escenario conservador, central y severo.	4 % (central)
Impacto (I)	Coste en euros: recuperación, sanciones, paradas.	2,5 M€ (central)
Pérdida esperada	P × I, por escenario.	100.000 €/año
Medida de mitigación	Acción concreta y su coste anual.	Revisión trimestral de accesos: 30.000 €/año
Pérdida tras mitigación	P × I con la medida aplicada.	25.000 €/año
Marco normativo	Referencias aplicables.	NIS2 · DORA
Fecha de revisión	Última revisión y próxima prevista.	Trimestral
Hipótesis	Supuestos en los que se basa la estimación.	Ver registro de hipótesis

Glosario

Término	Significado
Activo digital	Sistema, dato, modelo, servicio o dispositivo con valor para la organización.
Acceso privilegiado	Permiso que permite modificar configuraciones, datos o sistemas críticos.
Contención	Tiempo que transcurre desde la detección de un incidente hasta que su impacto queda limitado.
Cadena de suministro	Conjunto de proveedores y terceros que aportan software, servicios o acceso a sistemas.
DORA	Reglamento (UE) 2022/2554, sobre resiliencia operativa digital del sector financiero.
Exposición	Suma de pérdidas esperadas de un dominio, con costes de activos sin uso o sin retorno.
Linaje del dato	Registro del origen y de las transformaciones de un dato hasta su uso final.
NIS2	Directiva (UE) 2022/2555, sobre medidas de ciberseguridad en sectores esenciales e importantes.
Pérdida esperada	Probabilidad anual multiplicada por el impacto económico de un riesgo.
Playbook	Procedimiento documentado de respuesta a un tipo de incidente concreto.
Reglamento de IA	Reglamento (UE) 2024/1689, que establece obligaciones según el nivel de riesgo de los sistemas de IA.
Riesgo residual	Riesgo que permanece después de aplicar las medidas de mitigación.
Supervisión humana	Revisión y capacidad de intervención de una persona sobre un sistema automatizado.
Superficie de ataque	Conjunto de puntos por los que un atacante podría acceder a los sistemas.

Preguntas frecuentes del comité

¿Por qué expresar el riesgo en euros si las estimaciones son imprecisas?

Porque la alternativa, una escala cualitativa, tampoco es precisa y además no permite comparar. Un rango en euros obliga a explicitar supuestos, que es donde se concentra el valor del análisis.

¿Cuánto tiempo lleva implantar el modelo?

Un primer ciclo completo suele durar entre dos y tres semanas para un dominio. La implantación en los tres dominios, con propietarios y calendario de comité, puede llevar entre tres y seis meses según el tamaño de la organización.

¿Hace falta una herramienta específica?

No es imprescindible. Muchas organizaciones empiezan con una hoja de cálculo bien estructurada, usando la plantilla del anexo A. Cuando el número de riesgos crece, conviene una herramienta de gestión de riesgos que mantenga el histórico y los propietarios.

¿Quién debe estimar las probabilidades?

Las estimaciones deben hacerlas los propietarios de cada activo, con apoyo del equipo de riesgos para mantener un criterio común. Conviene que dos personas independientes revisen las estimaciones de los riesgos de mayor impacto.

¿Cómo se relaciona el modelo con el presupuesto anual?

El modelo no sustituye al presupuesto, pero lo informa. Cada partida puede asociarse a una reducción de exposición esperada. Las partidas sin reducción asociada se revisan con más detalle en la siguiente planificación.

¿Qué pasa si un riesgo se materializa?

Se analiza la causa, se actualiza la estimación de probabilidad e impacto y se revisa la medida de mitigación. El incidente se incorpora al registro de hipótesis, y el informe del trimestre siguiente lo recoge con su efecto sobre la exposición.

¿El marco sustituye al asesoramiento legal?

No. El marco ayuda a organizar y priorizar, pero la interpretación de la normativa aplicable a cada organización requiere asesoramiento jurídico especializado.